Risk register

Baseline: 2026-11-05. These risks come from design review and repository checks, not executed lab security tests. Likelihood and impact are planning judgments; RK-17 records an observed metadata finding. Each row identifies a mitigation and the person responsible for the remaining decision. Owner risk acceptance remains pending unless explicitly recorded. See the glossary for specialist terms.

Table 1. Document

ID	Risk / likelihood / impact	Mitigation and next evidence	Residual condition / owner
RK-01	Lab traffic reaches home/production through a shared uplink, administrator laptop, bridge, VPN, or IPv6 path / medium / critical	Offline baseline; private cable/route/adapter inventory; independent egress boundary; T01/T02 using mocks	Blocks online stages until inspected topology approved; owner + architect
RK-02	Proxmox installer destroys existing disk data / medium / critical	Stage A read-only inventory, exact-disk approval, verified backup/recovery, physical console, Stage B destructive scope	No installation authorized by Task 001; owner
RK-03	Single NVMe/host failure loses the lab or evidence / medium / high	Off-compute encrypted supported backups, private key custody, timed isolated T19 restore	No HA or same-disk backup claim; backup device/capacity unverified; owner
RK-04	Guest disks, snapshots, updates, or logs exhaust 512 GB storage / high / high	248 GiB guest ceiling, host/media/snapshot ledger, at least 80 GiB free, rotation/alerts; measure actual capacity and event rate	Workload/retention may need reduction or approved storage; engineer
RK-05	Supplied hardware/firmware/NIC/OS assumptions are wrong / medium / high	Verify actual hardware/SLAT/CPU support/storage/console before selecting software and topology	RAM alone does not prove compatibility or safe network design; owner
RK-06	Permissive remote default, corporate auto-enrollment, broad connector, or overlay bypass exposes extra resources / medium / critical	Separate lab identity/environment; pre-enrollment policy; one resource/ports; independent firewall/host restrictions; T13/T14	External vendor dependency and cached-session limits persist; engineer + owner
RK-07	PKI misconfiguration grants impersonation or root trust escapes lab / medium / high	Offline root/no NIC, constrained templates, lab-only trust, private keys, revocation application tests	No HSM; one owner limits role separation; engineer
RK-08	DNS/time/AD protocol restrictions break required functions or allow bypass / medium / high	Version-specific dependency matrix, lab resolvers/time, functional and negative cases, explicit encrypted-DNS limits	Do not fix by allowing all services; engineer

ID	Risk / likelihood / impact	Mitigation and next evidence	Residual condition / owner
RK-09	Publication leaks a secret, real address, raw evidence, or proprietary content / medium / critical	Private outside-repo storage, deny filenames/binaries, focused scans, staged/history and manual full-content review	Scanner has incomplete pattern coverage; publisher owns each artifact review
RK-10	Evaluation expires or software plan/licensing blocks activation, logging, MFA, posture, or retention / medium / high	Current official terms review at stage entry; expiry register and feature matrix; no corporate keys or unapproved purchases	If safe activation/export unavailable, stage remains pending or scope changes explicitly; owner
RK-11	Missing/altered logs, clock drift, or insufficient retention creates false confidence / medium / high	Six-source inventory, 20-event timing sample, time checks, collector ACLs/rotation/health alert, private originals	Single-host collector is not immutable; thirty-day design is not observed retention; engineer
RK-12	Overstated Zero Trust/compliance/resume outcomes misrepresent a small lab / medium / high	Requirement/test/evidence traceability, named unsupported features, proposed vs verified status, separate owner UAT	Project mapping is educational and not an official compliance crosswalk; technical lead
RK-13	Upstream media/action/dependency compromise or offline patch lag / medium / high	Official integrity checks, supported versions, pinned read-only CI action, minimal dependencies, approved update path	Pinning does not prove safety; recheck advisories before implementation; engineer
RK-14	Hypervisor/admin compromise defeats virtual segmentation / low-medium / critical	Dedicated admin path, supported MFA, scoped roles, no production credentials, independent physical separation and recovery	Single-host trust is a lab limitation; owner
RK-15	Documented PR convention is bypassed without repository enforcement / medium / medium	Focused branches/PR reviews and CI; owner decides rulesets/required checks/reviewer model	No protection/ruleset configuration silently applied; owner
RK-16	Directory/CA snapshot rollback corrupts identity or revocation state / medium / high	Supported system-state/CA backups, isolated restores, dependency order, no duplicate live DC	Recovery procedures must match selected software versions; engineer
RK-17	Existing public commits contain non-noreply author/committer email metadata / observed / privacy policy finding	T2 identified owner README edits and the GitHub-generated PR 1 merge; addresses withheld from reports. Verify noreply identity for both fields on every new commit/merge; preserve existing history	Removing historical metadata requires a separate owner-approved history change; account email/privacy preference is an owner decision
ID	**Risk / likelihood / impact**	**Mitigation and next evidence**	**Residual condition / owner**
RK-18	Generated PDFs drift from source, lose navigation/content, or render unreadably /	Pinned toolchain, source/output hashes,	Automated extraction does not replace visual

ID	Risk / likelihood / impact	Mitigation and next evidence	Residual condition / owner
	medium / medium	deterministic fresh rebuild, text/link/page checks, and representative rendered-page inspection	review; owner PDF/UAT acceptance remains separate

1. Handling and escalation

Resolve blocking risks before a dependent stage. Record new risks with trigger, owner, severity, mitigation, evidence, residual risk, and due stage. Any unexpected protected connectivity, secret exposure, uncertain destructive target, or absent recovery method stops the affected work. Use the approved isolation/rollback plan, preserve private evidence, and seek scope-specific owner direction before continuing dependent changes.

No risk acceptance, purchase, infrastructure operation, licensing choice, or stage advancement is implied by this register. Track resulting choices in DECISIONS.md.